



IMAGE LIBRARY GUIDE

ORGANIZE.
STORE.
SHARE.
INSPIRE.



ORGANIZE



STORE



SHARE

PhotoLib 管理员使用指南

系统管理 · 技术架构 · 部署运维

作者：PhotoLib 项目组

组织：校园摄影部图片工作站

时间：2026 年 9 月

版本：1.0

本指南面向系统管理员（ADMIN），介绍系统的技术架构、部署方式、
后台管理功能与日常运维要点。

目录

第 1 章 认识这套系统	1
1.1 一句话介绍	1
1.2 系统由哪几块组成	1
1.3 管理员的定位	2
第 2 章 技术架构详解	3
2.1 整体结构	3
2.2 图片是怎么处理的	3
2.3 系统靠什么保证安全和稳定	3
第 3 章 部署与运行	5
3.1 环境要求	5
3.2 构建可部署的 JAR	5
3.3 在 Linux 上用 systemd 运行	6
第 4 章 生产环境配置	7
4.1 配置从哪来	7
4.2 常用环境变量	7
第 5 章 账号与权限体系	9
5.1 三种角色	9
5.2 权限组与权限码	9
5.3 数据范围与图库可见范围	9
第 6 章 后台管理	11
6.1 账号管理	11
6.2 校区与负责人校区	11
6.3 权限组	11
6.4 品牌定制	11
6.5 审计日志	11
6.6 数据备份	12
第 7 章 数据安全性与运维	13
7.1 数据库备份与回滚	13
7.2 自动的自我保护任务	13
7.3 登录防护	14
7.4 成员招募的匿名入口	14
第 8 章 旧系统数据迁移（如需）	15

第 9 章 日常巡检清单

16

第 1 章 认识这套系统

内容提要

- PhotoLib 是什么
- 它由哪些部分组成
- 管理员在其中扮演什么角色

1.1 一句话介绍

PhotoLib 是一套面向校园摄影部门的**图片工作站**。它把摄影部日常的一整条工作线串了起来：立项选题 → 发布图片需求 → 校区负责人接单 → 上传与管理图片 → 标记采用 → 统计被引张数和工时 → 导出数据。此外还带有站内消息、成员招募、好图精选、文档中心等协作功能。

系统只有一个网站入口，所有人（管理员、部长、校区负责人）都用同一个地址登录，看到的菜单和能做的操作由**账号权限**决定。

1.2 系统由哪几块组成

表 1.1: 系统的技术组成

部分	说明
前端页面	用户在浏览器里看到的界面。用 React 19 + Ant Design 6 编写，单页应用。
后端服务	处理业务逻辑、权限校验、数据读写。用 Java 21 + Spring Boot 4 编写。
数据库	MySQL 8，保存账号、项目、图片记录、工时等结构化数据。
文件存储	保存图片本身。生产环境用阿里云 OSS（私有桶），本地开发用磁盘。
邮件服务	阿里云 DirectMail，用于发送通知邮件。
图片处理	一套原生组件（Zig + libjpeg-turbo/stb/libvips），负责压缩、生成预览图。

打包方式

前端和后端最终打包成**同一个 JAR 文件**运行。也就是说，部署时你只需要一个 Java 程序，不需要单独部署前端网站、也不需要服务器上装 Node。构建时 Maven 会自动把前端页面塞进后端 JAR 的静态资源里。

1.3 管理员的定位

管理员（角色代码 ADMIN）拥有系统**最高权限**，可以管理一切资源：账号、校区、权限组、品牌、审计日志、存储对账、数据库备份等。本指南的重点，就是帮助你理解系统结构，并用好这些管理能力。

一条贯穿全书的安全原则

后端才是权限的最终边界。前端「藏起某个按钮」只是界面效果，不等于真的没有权限。任何一次操作能不能做，都由后端根据账号权限重新判断。因此配置权限时，请以**权限组的授权**为准，不要以为「界面上看不到就做不了」。

第 2 章 技术架构详解

内容提要

- ❑ 前后端如何分工
- ❑ 系统靠哪些机制保证安全与稳定
- ❑ 图片是怎么被处理和存储的

2.1 整体结构

所有后端接口都以 `/api/v1` 开头。前端使用哈希路由（地址里带 `#`，例如 `/#/projects`），这样即使前端被打包进后端 JAR、从服务器根路径访问，刷新页面也不会 404。

后端按业务领域分包，每个包大致遵循三层结构：

- **Controller**：接收 HTTP 请求、校验参数、做权限判断。
- **Service**：真正的业务规则都写在这里。
- **Mapper**：用 MyBatis-Plus 访问数据库。

主要业务包包括：项目（project）、需求（request）、图片（photo）、采用（adoption）、工时（worklog）、统计（statistics）、通知（notification）、审计（audit）、存储（storage）、招募（recruitment）、文档（doc）、迁移（migration）、认证（auth）、后台（admin）等。

2.2 图片是怎么处理的

图片从上传到能在图库里看到，中间经过一条受控的处理流水线：

1. 浏览器先算出图片的 SHA-256 指纹，向后端申请一个短时签名的直传地址。
2. 浏览器把原图直接传到对象存储（不经过后端服务器中转）。
3. 后端重新读取原图，校验文件类型、指纹是否一致，然后压缩出「成品图」和「预览图」。
4. 成品图用于下载，预览图（统一为 WebP 格式）用于图库缩略图展示。

为什么预览图用 WebP

同样的清晰度下，WebP 预览比 JPEG 小约三成、比无损 PNG 小十几倍，还自带透明通道支持。预览图质量由 `PREVIEW_COMPRESSION_RATIO` 控制（取值 0 到 1，默认 0.6）。

2.3 系统靠什么保证安全和稳定

- **登录安全**：访问令牌 + HttpOnly 刷新令牌；首次登录强制改密；登录失败限速与锁定；登录尝试全量审计。
- **私有存储**：图片放在私有对象存储桶里，浏览器只能拿到短时签名地址，不会暴露永久公共链接。
- **并发保护**：关键写操作使用乐观锁（版本号）和幂等键，避免重复提交、并发覆盖。
- **软删除**：图片、需求等不做物理删除，只打删除标记，误删可以恢复。

表 2.1: 图片相关的关键限制

项目	限制
支持的格式	仅 JPG / JPEG / PNG
单张图片大小	最大 100 MiB
成品图目标体积	10 MiB
单次批量上传	最多 100 张
ZIP 上传	压缩包最大约 1.5 GB，解压后总量最大 10 GiB
原图保留期	默认 30 天（生成成品图后才会按期清理原图）
签名下载地址有效期	默认 15 分钟

- **审计日志：**所有写操作都会记录到审计日志（谁、在什么时间、对什么资源、做了什么）。
- **自我保护：**多处关键任务带「熔断」——当发现异常范围过大（可能是配置错了）时，宁可什么都不做也不批量删数据。

第 3 章 部署与运行

内容提要

- ❑ 需要准备什么环境
- ❑ 怎么在 Linux 服务器上跑起来
- ❑ 怎么构建出可部署的程序

3.1 环境要求

- 运行环境：**Java 21**、**MySQL 8**。
- 构建环境（仅打包时需要）：Node.js 20+、Zig 0.16.x、CMake 3.24+、Ninja、NASM。
- Linux 运行还需要：glibc 2.28+、libstdc++.so.6（含 GLIBCXX_3.4.22）、libgcc_s.so.1。

部署机不需要构建工具

构建（打包 JAR）和运行是两回事。JAR 一旦打好，部署服务器上只要有 **Java 21** 即可，不需要 Node、Maven、Zig，也不需要单独部署前端。

3.2 构建可部署的 JAR

在开发机（已装好构建环境）上执行：

打包成一个 JAR

```
cd backend
.\mvnw.cmd clean package      # Windows
./mvnw clean package          # Linux / macOS
```

这条命令会自动安装隔离的 Node、构建 React 前端、编译两套原生图片组件（Windows / Linux），并生成 backend/target/photolib-backend-0.1.0-SNAPSHOT.jar。这个 JAR 里已经包含了后端、前端和图片组件。

用 GitHub Actions 自动发版

项目已配置好自动打包流水线。发布一个版本只需要推一个标签：

```
git tag v1.0.0 && git push origin v1.0.0
```

流水线会跑测试、打包、并自动创建带附件的 Release。带连字符的标签（如 v1.2.0-rc.1）会当作预发布处理。

3.3 在 Linux 上用 systemd 运行

建议用专用用户和 /opt/photolib 目录部署，把 JAR 和生产 .env 放进去。一个最简 systemd 单元如下：

```
[Unit]
Description=PhotoLib
After=network-online.target
Wants=network-online.target

[Service]
Type=simple
User=photolib
Group=photolib
WorkingDirectory=/opt/photolib
ExecStart=/usr/bin/java -jar /opt/photolib/photolib.jar
Restart=on-failure
RestartSec=5
SuccessExitStatus=143

[Install]
WantedBy=multi-user.target
```

启动并检查健康状态：

```
sudo systemctl daemon-reload
sudo systemctl enable --now photolib
sudo systemctl status photolib
curl --fail http://127.0.0.1:8080/api/v1/actuator/health
```

务必放在 HTTPS 反向代理后面

应用本身跑在 8080 端口。生产环境必须在它前面加一层 HTTPS 反向代理（如 Nginx），并且只允许反向代理访问应用端口，不要把 8080 直接暴露到公网。

第 4 章 生产环境配置

内容提要

❑ 敏感配置怎么注入

❑ 有哪些必须关注的环境变量

4.1 配置从哪来

敏感配置（数据库密码、存储密钥等）只能通过环境变量、JAR 工作目录下受限权限的 `.env`，或密钥管理服务注入。绝对不要把 AccessKey、桶地址、签名密钥或 `.env` 提交到代码仓库。

4.2 常用环境变量

环境变量	说明
DB_URL / DB_USERNAME / DB_PASSWORD	MySQL 连接配置
ADMIN_INITIAL_PASSWORD	首次启动的管理员密码，必须用强随机值
AUTH_SECURE_COOKIE	生产环境必须为 <code>true</code>
STORAGE_MODE	本地开发填 <code>local</code> ，生产填 <code>oss</code>
OSS_BUCKET / OSS_ENDPOINT / OSS_PUBLIC_ENDPOINT	私有桶、服务端 Endpoint、浏览器访问 Endpoint
OSS_ACCESS_KEY_ID / _SECRET	最小权限的 RAM 用户凭据
OSS_CORS_ALLOWED_ORIGINS	允许浏览器直传的站点来源，生产应显式配置
OSS_SIGNATURE_WINDOW	预览地址签发时刻取整窗口，默认 5m，须小于下载 TTL
PREVIEW_COMPRESSION_RATIO	预览图质量，0 到 1，默认 0.6
LOGIN_MAX_IDENTIFIER_FAILURES	单账号连续失败几次后锁定，默认 5
LOGIN_MAX_ADDRESS_FAILURES	单客户端地址累计失败几次后锁定，默认 40
LOGIN_FAILURE_WINDOW / LOGIN_LOCK_DURATION	失败计数窗口 / 锁定时长，均默认 15m
PHOTO_PROCESSING_THREADS	图片处理线程数，1 到 32，默认 1

环境变量	说明
STARTUP_MISSING_OBJECT_CLEANUP_ENABLED	启动时是否清理「成品图已丢失」的记录，默认 true
DATABASE_BACKUP_ENABLED	是否每天 0 点自动备份数据库，默认 true
DATABASE_BACKUP_RETENTION	备份保留时长，默认 30d
DATABASE_BACKUP_MINIMUM_RETAINED	无论保留期，至少保留几份成功备份，默认 7
DIRECTMAIL_*	邮件服务的地域、发信地址与凭据

首次上线务必做的三件事

1. 用强随机值设置 ADMIN_INITIAL_PASSWORD，首次登录后立刻改密。
2. 生产环境不要使用 local Profile、默认签名密钥或默认密码。
3. 把 OSS_CORS_ALLOWED_ORIGINS 收窄到你真实的站点来源，不要长期用 *。

第 5 章 账号与权限体系

内容提要

- ❑ 三种角色分别管什么
- ❑ 「图库可见范围」这个容易被忽略的开关
- ❑ 权限组、权限码、数据范围是怎么配合的

5.1 三种角色

表 5.1: 系统的三种角色

角色	代码	默认职责
管理员	ADMIN	管理账号、权限组、校区及全部业务资源，查看审计与告警
部长	MINISTER	管理项目 and 需求，维护采用记录，确认工时并导出统计
校区负责人	CAMPUS_MANAGER	处理授权校区内的需求、图片、通讯录与工时

系统不开放注册。首次启动时只有一个管理员账号，其余账号都由管理员创建。

5.2 权限组与权限码

角色只是一个大类，真正决定「能点哪些菜单、做哪些操作」的是权限组。每个账号属于一个权限组，权限组里勾选了一批权限码。内置权限组（ADMIN / MINISTER / CAMPUS_MANAGER）的名称和数据范围不可改，但你可以新建自定义权限组，自由组合权限码。

5.3 数据范围与图库可见范围

除了「能做什么」，权限组还控制「能看到谁的数据」。这里有两个正交（互不影响）的维度：

- 数据范围（data_scope）：管的是校区授权。GLOBAL 看全站，校区范围只看授权校区。
- 图库可见范围（photo_visibility）：管的是图库里看得到谁的图。SELF 只看本人上传、CAMPUS 看授权校区内全部、GLOBAL 看全站。

一个常见的调整场景

校区负责人默认图库可见范围是 SELF（只能看自己上传的图）。如果你希望某校区的负责人互相看得到本校区其他人上传的图片，就把他所在权限组的图库可见范围改成 CAMPUS。注意：放宽「看得到」不会连带放开「改、删、标记采用」——那些始终限本人上传。

表 5.2: 主要权限码（在「系统管理 → 权限组」里按分类勾选）

权限码	含义
PROJECT_VIEW / _CREATE / _COMPLETE	选题的查看 / 新建编辑发布 / 标记完成
PROJECT_ADOPT	标记或取消图片被引（采用）
REQUEST_VIEW / _CREATE / _CONFIRM	需求的接受提交 / 新建发布 / 确认退回
REQUEST_PHOTO_MANAGE	管理需求图片（上传、下载、删除）
PHOTO_VIEW / _UPLOAD / _DOWNLOAD / _DELETE	图库的看 / 传 / 下 / 删
WORKLOG_SUBMIT / _CONFIRM / _EXPORT	工时的填报 / 确认退回 / 导出
DIRECTORY_VIEW / _MANAGE	通讯录的查看 / 维护
STATISTICS_DOWNLOAD	统计数据的查看与下载
RECRUITMENT_VIEW / _PUBLISH	招募的查看 / 创建发布
FEATURED_MANAGE / DOC_MANAGE / MESSAGE_SEND	好图精选 / 文档 / 消息的管理发送
MANAGER_CAMPUS_ASSIGN	重新指定校区负责人的授权校区

第 6 章 后台管理

内容提要

❑ 「系统管理」页面能做哪些事

❑ 每一块的用途和注意点

管理员登录后，左侧菜单底部有**系统管理**入口（其他角色看不到）。它把管理能力集中在几个面板里。

6.1 账号管理

创建、编辑、停用、删除账号，重置密码，指定所属权限组。要点：

- 新账号首次登录会**强制改密**。
- 邮箱可留空；若填写，在未删除用户里必须唯一（保存时会自动转小写）。
- 登录标识可以是用户名，也可以是邮箱。
- 删除账号采用「释放用户名后软删除」：历史记录仍在，同一个用户名日后可以重新创建。
- 不能删除当前登录账号，也不能删除唯一仍启用的管理员。
- 停用、改密、删除账号都会**撤销**该用户的登录会话。

6.2 校区与负责人校区

维护校区列表（启用/停用），以及给校区负责人**指定授权校区**。校区停用后，其下的需求就不能再被接受。

6.3 权限组

新建自定义权限组、勾选权限码、设置数据范围和图库可见范围。内置三组不可删、名称与数据范围不可改，但图库可见范围可以调整（见上一章）。

6.4 品牌定制

配置产品名、Slogan 和图标（内置图标或上传图片）。保存后侧栏会立即更新，登录页、招募页等也会跟随。前端所有产品标识都从这里读取，**不再硬编码任何产品名**。

6.5 审计日志

- 仅管理员可访问。可按操作人、HTTP 动作、资源类型、关键词、起止日期筛选并分页。
- 结束日期按「次日零点之前」处理，所以选中的结束日**包含一整天**。
- 可导出 CSV（带 BOM，Excel 打开中文不乱码）。当前单次导出上限 10 万条。
- 审计只记录**写操作**；登录尝试（含失败）也会记录，但不会记录密码或请求体。

6.6 数据备份

系统管理 → 数据备份，这是只对管理员开放的能力，没有对应权限码、也无法授予自定义权限组。详见下一章。

存储对账与告警

系统会定期核对「数据库里的图片记录」和「对象存储里的实际文件」是否对得上，发现异常时写入**管理员告警**。你会在后台看到这些告警。它们大多是提醒你人工确认，而不是系统已经删了数据——恰恰相反，系统在拿不准时会保守地**不删**。

第 7 章 数据安全与运维

内容提要

- ❑ 数据库备份和回滚怎么用
- ❑ 匿名报名入口的运维红线
- ❑ 系统有哪些自动的自我保护任务

7.1 数据库备份与回滚

系统每天凌晨 0 点（Asia/Shanghai）自动把整库业务数据备份到对象存储。管理员也可以手动备份、下载、导入外部备份文件，或把数据库回滚到某个备份。要点：

- 备份是逻辑备份（gzip 压缩的 JSON，只含数据不含表结构），不依赖服务器上装 mysqldump。
- 表结构由 Flyway 管理，所以只能回滚到与当前结构版本一致的备份，跨版本的备份界面上不可回滚。
- 回滚前会自动生成一份 PRE_RESTORE 兜底备份，误操作后还能再退回来。
- 回滚在单个事务里完成，中途失败整体回滚，不会留下「删了一半」的库。
- 回滚只替换数据库，不会删除对象存储里的图片文件；但回滚后登录会话可能全部失效。

单实例假设

备份/回滚的并发控制目前假设单实例部署。如果将来要多实例部署，必须先改成数据库层的抢占锁，否则可能出现两个实例同时回滚。

7.2 自动的自我保护任务

系统在每次启动和运行期间会跑几个自动任务，理解它们有助于你看懂日志和告警：

表 7.1: 几个关键的自动任务

任务	作用与保护
启动缺失对象清理	核对成品图是否还在存储里；只有精确确认对象不存在才软删记录。已被采用的图只告警不删；缺失比例过高（疑似配置错误）时一张都不删并告警。
原图清理	到保留期且已生成可用图片的原图才会被删。
预览图重建	修改压缩比或换编码器后，在后台逐张重建预览图，不阻塞启动，失败只影响单张。
存储对账	定期核对数据库与存储，异常写管理员告警，不据此批量删数据。

看到告警不要慌

这些任务的设计原则是「宁可不动，也不误删」。看到带 ABORTED 字样的熔断告警，通常意味着存储配置出了问题（桶名、Endpoint、前缀或挂载点配错），应先排查配置，而不是怀疑数据真丢了。（告警名形如 PHOTO_MISSING_OBJECT_CLEANUP_ABORTED。）

7.3 登录防护

应用内做了两层防护：按账号和按客户端地址分别计失败次数并锁定；登录尝试全量进审计。但这不替代网关限流——应用只能看到已经到达它的请求。请务必在反向代理/网关上为 `/api/v1/auth/login` 配置独立限流。

7.4 成员招募的匿名入口

成员招募的公开报名页（`/#/recruitment`）是系统里唯一对未登录访客开放写操作的功能。上线前请注意：

网关必须承担的防护

`/api/v1/public/recruitments/**` 完全匿名。应用内的限流只是有界的纵深防护，不能替代网关限流：部署在反向代理后面时，应用拿到的往往是代理 IP，会被当作共享地址直接放行。因此必须在网关上为这些路径配置分布式限流。开放招募前，请用真实大小的样本包实测一次上传是否顺畅。

第 8 章 旧系统数据迁移（如需）

如果要从旧的 PhotoWarehouse 系统（PostgreSQL + OSS）迁移数据，脚本在 `scripts/` 目录下，采用可重入的两阶段流程：

1. `migrate_photowarehouse.py export`：从旧库导出完整 JSON 包。
2. `migrate_photowarehouse.py import`：复制 OSS 对象、写入新库、归档旧行。
3. `restore_project_photos.py`：按旧标签规则重建「一图多项目」的相册归属。

迁移前后须知

- 执行前必须备份数据库与 Bucket，并先启动一次新后端让 Flyway 升级到最新版本。
- 图片对象不下载、不重传，只复用旧的存储 key。
- 旧数据无法可靠推断的字段一律留空，尤其不能猜测图片校区。
- 确认迁移完成后，务必关闭迁移开关 `IS_MIGRATE`。

详细字段映射与命令见项目 `docs/` 下的迁移文档。

第 9 章 日常巡检清单

建议定期检查

1. 健康检查地址 `/api/v1/actuator/health` 是否正常。
2. 后台管理员告警里有没有新的存储/备份/迁移告警。
3. 数据库每日备份是否成功（可在数据备份面板查看）。
4. 审计日志量是否过大，是否需要制定保留与清理策略（登录审计会显著增加写入量）。
5. 反向代理/网关的限流规则是否仍对登录和招募匿名接口生效。
6. 存储桶的 RAM 凭据、CORS 配置是否仍然正确、最小权限。

更多技术细节

本指南是快速上手向导。更深入的模块业务规则、不变量和「改动会破坏什么」，请查阅项目根目录的 `AGENTS.md` 与 `README.md`。